Informe de revisión y auditoría

TechnoStore · Tienda en línea con dinero digital simulado

Programa: Análisis y Desarrollo de Software (ADSO),

ficha 3407799

Centro de formación: Centro de la Industria, la Empresa y los Servicios (SENA)

Aprendices:

Danna Michelle Farfan Ramírez,

Cristian Camilo Alegria Rivera,

Kevin Camilo Caballero Oliveros,

Deiner Smit Limas Lavao,

Juan Manuel Silva Castañeda

Código del informe: IRA-TS-001 · **Versión:** 2.0 ·

Fecha: 10/11/2026

Objeto revisado: TechnoStore, código del repositorio Nueva_carpeta_1.zip **Documento de referencia:** Plan de Aseguramiento de la Calidad PAC-TS-001 v1.0

Control de versiones del informe

Versión	Fecha	Descripción del cambio	Autor
2.0	10/11/2026	Versión 2.0 del informe de revisión y auditoría interna, con nueve no conformidades, seis observaciones y el dictamen de la sección 11, verificados contra el código	Equipo de calidad

1. Objetivo y alcance

El informe registra el resultado de la revisión y la auditoría interna del código, la base de datos, la configuración y el control de versiones de TechnoStore. Establece si el producto cumple el SRS v1.0 y el PAC, e identifica las no conformidades que deben corregirse antes de la entrega.

El alcance incluye los archivos del repositorio: `backend/endpoints/api.php`, `backend/config/config.php`, `backend/services/mailer.php`, `backend/endpoints/reporte.php`, `backend/libraries/xlsx.php`, `index.php`, `assets/js/app.js`, `database/bdcatalogo.sql`, `Anexos/SQL/bdcatalogo.sql`, `features/feedback/`, `.gitignore` y `README.md`.

No incluye pruebas de ejecución contra un servidor en producción, pruebas de penetración ni la revisión del historial de Git, porque el ZIP no contiene la carpeta `.git`.

2. Criterios de auditoría

Criterio	Fuente
Requerimientos funcionales RF-01 a RF-50	SRS v1.0, sección 4
Requerimientos no funcionales RNF-01 a RNF-16	SRS v1.0, sección 5
Reglas de negocio RN-01 a RN-15	SRS v1.0, sección 7
Características de calidad de producto	ISO/IEC 25010
Controles de seguridad de la aplicación	Observaciones O-01 a O-07 del SRS
Criterios de entrega y ciclo de vida de defectos	PAC-TS-001, secciones 3.1 y 6
Protección de datos personales y consumidor	Ley 1581 de 2012, Ley 1480 de 2011

3. Método

La revisión combinó cuatro técnicas:

1. **Revisión estática de código.** Lectura de cada archivo del alcance y comprobación de cada control con su línea de código.
2. **Contraste con el SRS.** Cada requerimiento se comparó con la función que lo implementa.
3. **Revisión de configuración.** Se revisaron `.gitignore`, `config.php`, las copias del script SQL y la estructura del repositorio.

4. **Revisión de registros.** Se contrastaron los registros de pruebas y de incidencias del equipo con el estado real del código.

Limitaciones del método: la revisión es estática. Las pruebas de concurrencia, de rendimiento, de contraste y de envío de correo no se ejecutaron, y el historial de Git no se revisó. Los hallazgos que dependen de ejecución se marcan como «pendiente de prueba».

3.1 Tipos de evaluación

La revisión de pares y la auditoría formal tienen objetivos distintos. Por eso este informe las separa.

Tipo	Propósito	Quién la hace	Dónde aparece en este informe
Revisión de pares	Encontrar defectos y transferir conocimiento técnico antes de integrar el código	Miembros del equipo, en cada Pull Request	Sección 8
Auditoría formal	Comprobar con evidencia si el producto cumple el SRS, el PAC y las normas	Evaluador independiente del equipo que desarrolló el sistema	Secciones 5, 6, 8.2, 9 y 11

3.2 Tipos de auditoría aplicados

- **Auditoría funcional (FCA):** ¿el producto hace lo que pide el SRS? Secciones 4 y 7.
- **Auditoría física (PCA):** ¿el paquete entregado corresponde a lo aprobado? Sección 8.2.
- **Auditoría de procesos y seguridad:** ¿se siguen los controles de cambios, de acceso y de seguridad? Secciones 8.1 y 9.

3.3 Fases del método

Fase	Actividad en este informe	Estado
Planificación	Alcance (sección 1), criterios (sección 2) y designación del evaluador por parte del docente revisor	Hecha. Auditor interno propuesto: Cristian Camilo Alegria Rivera
Preparación	Listas de verificación del PAC (sección 8). Se revisaron los archivos completos del alcance, sin muestreo	Hecha
Ejecución	Revisión de código, contraste con el SRS y revisión de registros (secciones 4 a 9)	Hecha. Las pruebas de ejecución están pendientes (observación OBS-

Fase	Actividad en este informe	Estado
		06)
Cierre y seguimiento	Recomendaciones priorizadas (sección 10), plan de acción con fechas (sección 11) y verificación de la eficacia de cada cierre	Pendiente de cierre de hallazgos

3.4 Cobertura del ciclo de vida

Se evaluaron las etapas de requisitos, de diseño y construcción, y de pruebas y liberación. La etapa de operación y cierre no se evaluó, porque el sistema no está en producción.

4. Resumen ejecutivo

Dictamen: no conforme para entrega. El código cumple la mayoría de los requerimientos funcionales, pero tiene dos no conformidades de seguridad abiertas, un control de sesión que no cumple el contrato del SRS y un registro de pruebas que no refleja el estado real.

Indicador	Resultado
Requerimientos funcionales conformes	42 de 50 (84 %)
Requerimientos funcionales parciales	7
Requerimientos funcionales no conformes	1 (RF-10)
Requerimientos no funcionales conformes	6 de 16 (38 %)
No conformidades abiertas	9, de las cuales 3 son de severidad Alta
Observaciones abiertas	6
Incidencias verificadas por quien las reportó	0 de 7

Las tres no conformidades que bloquean la entrega son la clave de ejemplo 123456 todavía aceptada, la falta de verificación de cuentas dadas de baja en sesiones abiertas y el posible fallo de escape en el botón Eliminar de categorías.

5. No conformidades

Una no conformidad es el incumplimiento verificado de un requisito del SRS, del PAC o de una norma aplicable. Se registran nueve. Las tres de severidad Alta bloquean la entrega.

ID	Severidad	Criterio	Condición	Causa	Efecto	Recomendación
NC-01	Alta	RNF-04, RN-15, O-01	La clave 123456 se acepta en el inicio de sesión y en el cambio de	La clave de ejemplo sigue en el código de la	Cualquier persona puede entrar a las	Eliminar la rama de la clave de ejemplo,

ID	Severidad	Criterio	Condición	Causa	Efecto	Recomendación
			contraseña para cuentas con hash de ejemplo. Evidencia: api.php, líneas 315 a 316 y 646	versión entregable	cuentas de ejemplo que sigan activas	retirar las cuentas de ejemplo y agregar una revisión automática que bloquee claves de ejemplo en el código
NC-02	Alta	RF-45	La sesión de un usuario dado de baja sigue activa. needLogin() solo verifica que exista una sesión. Evidencia: api.php, líneas 252 a 256	needLogin() no consulta el estado de la cuenta en cada petición	Un usuario dado de baja puede seguir operando hasta cerrar sesión	Verificar el campo activo en needLogin() en cada petición y cerrar las sesiones de las cuentas dadas de baja
NC-03	Alta	RNF-07	Posible inyección de JavaScript en el botón Eliminar de categorías. Evidencia: assets/js/app.js, línea 709. Pendiente de prueba	El nombre se escapa con ' dentro de un atributo onclick, y el navegador lo decodifica antes de ejecutar el código	Un nombre con comillas puede ejecutar código en el panel de administración	Pasar los datos con atributos data- y un listener, sin construir JavaScript con texto del usuario. Probar con nombres que contengan comillas
NC-04	Media	RF-10	La acción sesion responde 200 con user null cuando no hay sesión. Evidencia: api.php, líneas	La acción no aplica el código de error del contrato	La interfaz depende de un formato distinto al del SRS	Responder 401 «Sin sesión» cuando no hay sesión

ID	Severidad	Criterio	Condición	Causa	Efecto	Recomendación
			303 a 304			
NC-05	Media	RNF-05, O-02	No hay token anti-CSRF en las acciones POST y la cookie no define SameSite	No se implementó la protección contra peticiones entre sitios	Un sitio externo podría enviar acciones en nombre de un usuario con sesión activa	Token por sesión validado en cada POST y session.cookie_samesite en Lax o Strict
NC-06	Media	O-03	login no limita los intentos fallidos ni registra los fallos	No hay contador de intentos ni registro de fallos	Riesgo de adivinación de contraseñas	Bloqueo temporal por correo e IP, y registro de los fallos
NC-07	Media	Control de configuración	Existen dos copias de bdcatalogo.sql que difieren en 94 líneas. Evidencia: database/ y Anexos/SQL/	Las copias se mantuvieron por separado, sin una fuente única	Puede instalarse una base de datos distinta de la aprobada	Dejar una sola fuente y eliminar la otra
NC-08	Media	RNF-06	migrar() muestra al usuario el mensaje de error de MySQL. Evidencia: api.php, línea 150	El manejo de errores no separa el mensaje técnico del mensaje para el usuario	Se expone información interna de la base de datos	Mensaje genérico para el usuario y detalle solo en el log con error_log()
NC-09	Baja	PAC, sección 3.1	El registro de pruebas marca «Funcional» en Estado y cuenta 7 errores verificados, cuando ninguno	El registro no usa los estados definidos en el PAC	El avance aparece mayor al real	Usar Aprobado o Fallido en Estado y corregir el conteo de errores verificados a

ID	Severidad	Criterio	Condición	Causa	Efecto	Recomendación
			está verificado			0

6. Observaciones

Las observaciones no incumplen un requisito por sí solas, pero deben resolverse o documentarse antes de la entrega.

ID	Observación	Evidencia	Acción recomendada
OBS-01	RNF-09 dice que el envío de correo es asíncrono. El código lo envía dentro de la petición, después del COMMIT	backend/services/mailer.php y la transacción de confirmación	Corregir el SRS o el código para que coincidan
OBS-02	El valor por defecto de DB_HOST es 127.0.0.1:8080. El README indica el puerto 3306	backend/config/config.php, línea 13	Cambiar el valor por defecto o documentarlo
OBS-03	La versión mínima de PHP no coincide: 7.4 en el README y 8.0 en el SRS	README.md y RNF-12	Definir una versión y probarla
OBS-04	El módulo features/feedback no tiene casos de prueba en el PAC	features/feedback/	Agregar casos CP-18 a CP-21
OBS-05	Quedan archivos residuales: configof.php, que no usa ningún archivo, y dos .patch en la raíz	Raíz del repositorio	Eliminarlos antes de la entrega
OBS-06	Las pruebas de concurrencia, rendimiento, responsive, contraste, envío de correo y versiones mínimas no se han ejecutado	RNF-02, RNF-08, RNF-12, RNF-13, RNF-14 y RNF-09	Ejecutar las pruebas PNF-01 a PNF-06 del PAC

7. Conformidades verificadas

Los siguientes controles se comprobaron en el código y cumplen lo especificado.

Control	Evidencia	Requisito
Consultas con parámetros y errores de PDO en modo excepción	backend/config/config.php, líneas 34 a 36	RNF-06
Credenciales leídas de variables de entorno, sin claves escritas en el código	backend/config/config.php, líneas 13 a 17 y 47 a 53	O-07
Control de acceso por rol y por sesión	needLogin() en api.php, líneas 252 a 256; needAdmin() en la	RF-13

Control	Evidencia	Requisito
	línea 258	
Validación de imágenes: tamaño máximo de 2 MB, comprobación del tipo real con getimagesize(), nombre aleatorio	backend/endpoints/api.php, líneas 694 a 701	RF-36
Cancelación por el cliente solo en estado PENDIENTE	api.php, línea 482	RF-20, RN-07
Confirmación de pedido en transacción con validación de estado y de stock	api.php, líneas 457 y 462	RF-18, RN-03
Matriz de transiciones de estado implementada	api.php, arreglo $flujo en la línea 558	RN-06
Reembolso idempotente	api.php, línea 231	RF-27, RN-05
Migración de esquema idempotente, con consultas a information_schema y tolerancia al error 1060	api.php, líneas 80 a 150	RNF-11
Tiempo máximo de espera de 12 segundos en servicios externos	api.php, línea 58	RNF-09
Límite de 20 reportes de errores cada 10 minutos por usuario	features/feedback/endpoint.php, líneas 83 a 86	Control de abuso del módulo de reportes
Reportes de errores solo para usuarios con sesión; detalle máximo de 2.000 caracteres	features/feedback/endpoint.php, líneas 78 y 79	Control de acceso del módulo

8. Revisión de código y control de versiones

La lista de revisión del PAC (sección 4.3) se aplicó al código actual. El resultado es el siguiente.

Criterio	Resultado	Evidencia
Sin marcas de conflicto en los archivos	No verificable	El ZIP no incluye .git
La página carga sin errores de PHP	No verificado	No se abrió en navegador. La sintaxis de los archivos PHP no se comprobó con php -l
Consultas con parámetros	Cumple	config.php, líneas 34 a 36
Sin contraseñas ni claves en el código	No cumple	api.php, líneas 315 y 646 (NC-01)

Criterio	Resultado	Evidencia
Permisos con needAdmin() y needLogin()	Cumple	api.php, líneas 252 a 258
Base de datos actualizada en el script	No cumple	Dos copias que difieren (NC-07)
Sin archivos temporales, vendor/ ni config.php	Parcial	Ver la tabla de control de versiones
Flujo modificado probado	No verificado	No hay evidencia de ejecución en esta revisión

8.1 Configuración del repositorio

Elemento	Estado	Observación
vendor/ excluido	Cumple	.gitignore, línea de vendor/
config.php excluido, con excepción para backend/config/config.php	Cumple	.gitignore, líneas de config.php y !backend/config/config.php
Archivos *.swp excluidos	No cumple	No aparece en .gitignore
Archivos .patch fuera de la raíz	No cumple	dinero-digital.patch y frontend-dinero-digital.patch siguen en la raíz
Protección de ramas en GitHub	No verificable	Configuración del repositorio remoto, fuera del ZIP
Historial sin credenciales expuestas	No verificable	Requiere la carpeta .git y la revisión de commits anteriores

8.2 Auditoría física (PCA)

La auditoría física compara el paquete entregado con la configuración aprobada. Resultado: no se puede concluir, porque el paquete no incluye el historial de Git.

Verificación	Resultado	Evidencia
Existe una etiqueta de versión en el repositorio	No verificable	El ZIP no incluye .git
El paquete tiene una huella de integridad registrada (hash)	No cumple	No hay archivo de hash en el paquete
El paquete corresponde al commit aprobado	No verificable	Sin historial de Git
Los archivos del paquete coinciden con el repositorio aprobado	No cumple	Dos copias de bdcatalogo.sql que difieren (NC-07)

Verificación	Resultado	Evidencia
El paquete contiene solo archivos del producto	No cumple	configof.php y dos archivos .patch en la raíz (OBS-05)

Recomendación: etiquetar la versión (por ejemplo, v1.0) en la rama main, registrar el hash SHA-256 del paquete entregado y entregar solo los archivos del producto.

9. Revisión de seguridad

Nueve controles de seguridad se revisaron en el código. Cuatro cumplen, cuatro no cumplen y uno está pendiente de prueba.

Control	Estado	Referencia
Contraseñas con hash bcrypt y verificación con password_verify	Cumple	RNF-04
Regeneración del identificador de sesión tras autenticarse	Cumple	RNF-05
Consultas preparadas con parámetros enlazados	Cumple	RNF-06
Control de acceso por rol	Cumple	RF-13
Ausencia de claves de ejemplo activas	No cumple	NC-01
Sesión de cuentas dadas de baja	No cumple	NC-02
Escape de datos en atributos onclick	Pendiente de prueba	NC-03
Protección CSRF	No cumple	NC-05
Límite de intentos de inicio de sesión	No cumple	NC-06

Los controles que no cumplen determinan el dictamen de la sección 12.

10. Recomendaciones priorizadas

Las recomendaciones se ordenan por severidad y por el riesgo que cierran. Cada una corresponde a una o más no conformidades de la sección 5. Se corrigen los controles del proceso, no a las personas.

1. **Inmediato (bloquean la entrega):** retirar la clave de ejemplo (NC-01), cerrar las sesiones de las cuentas dadas de baja (NC-02) y corregir el escape de datos en el botón Eliminar de categorías (NC-03). Son las tres no conformidades de severidad Alta.
2. **Antes de la entrega:** corregir el código de respuesta de la sesión (NC-04), proteger las peticiones POST contra CSRF (NC-05), limitar los intentos de inicio de sesión (NC-06), dejar una sola copia del script SQL (NC-07) y ocultar el detalle de errores de MySQL al usuario (NC-08).
3. **Antes de la entrega, en el registro de pruebas:** corregir el registro de casos de prueba (NC-09) y ejecutar las pruebas pendientes de la observación OBS-06.

4. **Decisiones de configuración:** definir la versión de PHP (OBS-03), corregir el valor por defecto de DB_HOST (OBS-02), eliminar los archivos residuales (OBS-05) y documentar la diferencia entre RNF-09 y el código (OBS-01).
5. **Control de versiones:** etiquetar la versión y registrar su hash (sección 8.2), y revisar el historial de Git para confirmar que no hay credenciales expuestas (sección 8.1).

11. Plan de acción y seguimiento

Cada no conformidad se cierra cuando su acción correctiva está aplicada y la verificación la confirma. Quien verifica no es quien corrige. Las acciones coinciden con las del plan de acción del PAC (sección 10).

Las fechas son propuestas. El docente revisor las confirma antes de iniciar las acciones.

NC	Acción correctiva	Responsable	Fecha límite (propuesta)	Criterio de cierre (verificación)
NC-01	Eliminar la rama de la clave de ejemplo y retirar las cuentas de ejemplo	Juan Manuel Silva Castañeda	13/11/2026	Un intento de inicio de sesión con 123456 en cuentas de ejemplo debe fallar
NC-02	Verificar el campo activo en needLogin()	Juan Manuel Silva Castañeda	13/11/2026	Una cuenta dada de baja con sesión abierta debe recibir 401 en la siguiente petición
NC-03	Pasar los datos con atributos data- y un listener	Cristian Camilo Alegria Rivera	13/11/2026	Una categoría con comillas en el nombre no debe ejecutar código
NC-04	Responder 401 «Sin sesión» en la acción sesion	Juan Manuel Silva Castañeda	20/11/2026	Llamar sesion sin sesión debe devolver 401
NC-05	Token por sesión validado en cada POST y SameSite en la cookie	Juan Manuel Silva Castañeda	20/11/2026	Un POST sin token debe ser rechazado
NC-06	Contador de intentos fallidos por correo e IP	Juan Manuel Silva Castañeda	20/11/2026	Cinco intentos fallidos seguidos deben bloquear el acceso durante un tiempo
NC-07	Dejar una sola copia de bdcatalogo.sql	Deiner Smit Limas Lavao	20/11/2026	Las copias deben ser idénticas o debe existir una sola
NC-08	Mensaje genérico al usuario y detalle en el log	Juan Manuel Silva Castañeda	20/11/2026	Un error en migrar() no debe mostrar detalles de MySQL al usuario
NC-09	Corregir la columna	Danna	27/11/2026	El registro muestra Aprobado o

NC	Acción correctiva	Responsable	Fecha límite (propuesta)	Criterio de cierre (verificación)
	Estado y el conteo de errores verificados	Michelle Farfan Ramírez		Fallido, y los errores verificados suman 0

12. Dictamen y condiciones de cierre

Dictamen: no conforme para entrega, con fecha 10/11/2026. Hay tres no conformidades de severidad Alta abiertas (NC-01, NC-02 y NC-03) y cinco de severidad Media.

La entrega se reevalúa cuando se cumplan estas condiciones:

1. Las nueve no conformidades de la sección 5 están cerradas con su verificación de la sección 11.
2. La verificación de las no conformidades Alta se hace por una persona distinta a la que las corrigió.
3. Las pruebas OBS-06 (concurrencia, rendimiento, responsive, contraste, correo y versiones) se ejecutaron y sus resultados se registraron en el PAC.
4. La decisión de versión de PHP (OBS-03) está tomada y documentada en el manual técnico.

Una nueva auditoría revisa solamente los puntos abiertos. No repite la revisión completa, salvo que se modifique la arquitectura.

11.1 Firmas

Rol	Nombre	Firma	Fecha
Auditor interno (propuesto)	Cristian Camilo Alegria Rivera		
Analista de calidad	Danna Michelle Farfan Ramírez		
Revisor de código	Juan Manuel Silva Castañeda		
Administrador de Git y del tablero	Deiner Smit Limas Lavao		
Docente revisor			

El auditor propuesto debe confirmar que no programó los módulos auditados. Si los programó, el rol pasa a otro integrante.